SYSTEM AND COMMUNICATION PROTECTION

WyIT - 3007

PURPOSE: This policy establishes guidelines for system and communications protection for Information Technology (IT), Operational Technology (OT) and Internet of Things (IoT) resources.

I. APPLICABILITY

This policy applies to all Executive Branch agencies, boards, and commissions staff (collectively referred to as "agencies"). This policy is also applicable to consultants, affiliates, and temporary employees.

II. DEFINITIONS

All definitions for this policy are located in the Policy Dictionary.

III. EXCEPTIONS

Any exceptions provided to the following policy must abide by the WyIT - 3002 - Security Exception Request policy.

IV. APPLICATION PARTITIONING

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Separate user functionality from information system management functionality either logically or physically.
- Information system management functionality includes, for example, functions necessary to administer databases, network components, workstations, or servers and typically requires privileged user access.

V. INFORMATION IN SHARED RESOURCES

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Prevent unauthorized and unintended information transfer via shared system resources.
    - This control prevents information, including encrypted representations of information, produced by the actions of prior users/roles from being available to any current users/roles (or current processes) that obtain access to shared system resources (e.g., registers, main memory, hard disks) after those resources have been released back to information systems.

VI. DENIAL OF SERVICE PROTECTION

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Ensure that the information system protects against or limits the effects of denial of service attacks.
- The information system restricts the ability of individuals to launch denial-of-service attacks against other information systems.

VII. BOUNDARY PROTECTION

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Monitor and control communications at the external boundary of the system and at key internal boundaries within the system.
- Implement sub-networks for publicly accessible system components that are physically and/or logically separated from internal organizational networks and connected to external networks or information systems only through managed interfaces consisting of boundary protection devices arranged in accordance with an organizational security architecture.
- Managed interfaces include, for example, gateways, routers, firewalls, guards, network-based malicious code analysis and virtualization systems, or encrypted tunnels implemented within security architecture.

VIII. TRANSMISSION CONFIDENTIALITY AND INTEGRITY

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Deploy information systems that protect the confidentiality and integrity of transmitted information.
- This control applies to both internal and external networks and all types of information system components from which information can be transmitted (e.g., servers, mobile devices, notebook computers, printers, copiers, scanners, facsimile machines).

IX. NETWORK DISCONNECT

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Ensure information systems are configured to terminate the network connection associated with a communications session at the end of the session or after a maximum of 45 minutes of inactivity or 9 hours of continuous connection; this control applies to both internal and external networks.
- Terminating network connections associated with communications sessions includes, for example, de-allocating associated TCP/IP address/port pairs at the operating system level or de-allocating networking assignments at the application level if multiple application sessions are using a single operating system-level network connection.

X. CRYPTOGRAPHIC KEY ESTABLISHMENT AND MANAGEMENT

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Establish and manage cryptographic keys for required cryptography employed within the information system.

XI. CRYPTOGRAPHIC PROTECTION

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Implement cryptographic uses and type of cryptography required in accordance with applicable federal and state laws, directives, policies, regulations, and standards.

- Cryptography can be employed to support a variety of security solutions, including, for example, the protection of classified and Controlled Unclassified Information, the provision of digital signatures, and the enforcement of information separation when authorized individuals have the necessary clearances for such information but lack the necessary formal access approvals.

XII. COLLABORATIVE COMPUTING DEVICES

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Prohibit non CIO authorized remote activation of collaborative computing devices.
- Provide an explicit indication of use to users physically present at the devices.
- Collaborative computing devices include, for example, networked whiteboards, cameras, and microphones. Explicit indication of use includes, for example, signals to users when collaborative computing devices are activated.

XIII. PUBLIC KEY INFRASTRUCTURE CERTIFICATES

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Issue public key certificates under the CIOs approved public key certificates from an approved service provider.
- Manage information system trust stores for all key certificates to ensure only approved trust anchors are in the trust stores.

XIV. MOBILE CODE

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Define acceptable and unacceptable mobile code and mobile code technologies.
- Establish usage restrictions and implementation guidance for acceptable mobile code and mobile code technologies.
- Authorize, monitor, and control the use of mobile code within the information system.

- Decisions regarding the employment of mobile code within organizational information systems are based on the potential for the code to cause damage to the systems if used maliciously.

XV. VOICE OVER INTERNET PROTOCOL

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Establish usage restrictions and implementation guidance for Voice over Internet Protocol (VoIP) technologies based on the potential to cause damage to the information system if used maliciously.
- Authorize, monitor, and control the use of VoIP within the information system.

XVI. SECURE NAME / ADDRESS RESOLUTION SERVICE (AUTHORITATIVE SOURCE)

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Provide additional data origin authentication and integrity verification artifacts along with the authoritative name resolution data the system returns in response to external name/address resolution queries.
- Provide the means to indicate the security status of child zones and (if the child supports secure resolution services) enable verification of a chain of trust among parent and child domains when operating as part of a distributed, hierarchical namespace.
- This control enables external clients, including, for example, remote Internet clients, to obtain origin authentication and integrity verification assurances for the host/service name to network address resolution information obtained through the service.

XVII. SECURE NAME / ADDRESS RESOLUTION SERVICE (RECURSIVE OR CACHING RESOLVER)

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Ensure information systems that request and perform data origin authentication and data integrity verification on the name/address resolution responses the system receives from authoritative sources.

- Each client of name resolution services either performs this validation on its own or has authenticated channels to trusted validation providers. Information systems that provide name and address resolution services for local clients include, for example, recursive resolving or caching domain name system (DNS) servers.

XVIII. ARCHITECTURE AND PROVISIONING FOR NAME / ADDRESS RESOLUTION SERVICE

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Ensure that the information systems that collectively provide name/address resolution services for an organization are fault-tolerant and implement internal/external role separation.
- Employ at least two authoritative domain name system servers, one configured as the primary server and the other configured as the secondary server, to eliminate single points of failure and to enhance redundancy.
- Information systems that provide name and address resolution services include, for example, DNS servers.

XIX. SESSION AUTHENTICITY

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Ensure the information system protects the authenticity of communication sessions.
    - This control addresses communications protection at the session versus packet level (e.g., sessions in service-oriented architectures providing web-based services) and establishes grounds for confidence at both ends of communications sessions in the ongoing identities of other parties and in the validity of information transmitted.

XX. PROTECTION OF INFORMATION AT REST

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Ensure the information system protects the confidentiality and integrity of State information systems at rest.

- This control addresses the confidentiality and integrity of information at rest and covers user information and system information. Information at rest refers to the state of information when it is located on storage devices as specific components of information systems.

XXI. PROCESS ISOLATION

All applicable agencies and/or affiliates identified in the scope of this policy shall:

- Ensure the information system maintains a separate execution domain for each executing process.
- Information systems can maintain separate execution domains for each executing process by assigning each process a separate address space. Each information system process has a distinct address space so that communication between processes is performed in a manner controlled through the security functions, and one process cannot modify the executing code of another process.

REFERENCES: This policy has no supporting references to websites, other policies, or federal or state statutes.

DOCUMENT HISTORY

ORIGINAL SUBMISSION				
SUBMITTED ON	**SUBMITTED BY**	**APPROVED BY**	**APPROVED BY DATE(S)**	**EFFECTIVE DATE**
June 2024	ETS Governance, Risk and Compliance	Public Comment Period	05/10/2024 - 05/24/2024	June 2024

REVISIONS		
LAST REVISION DATE	**LAST REVISED BY**	**LAST APPROVED BY**

REVIEWS		
LAST REVIEW DATE	**LAST REVIEWED BY**	**NEXT REVIEW DATE**